

Requirements

Table of Contents

- Requirements
 - Functional Requirements
 - Non-Functional Requirements
 - User Stories
 - Role/Permission Matrix
 - Business Rules
 - Remaining Production Backlog
 - Requirement-To-Endpoint Traceability

Requirements

Functional Requirements

ID	Requirement	Priority	Acceptance Criteria
FR-01	Public landing page shows academy information, branches, styles, levels, contact/enrollment request.	High	Visitor can open <code>/</code> , read branches/styles/levels and submit an enrollment request.
FR-02	Google OAuth registration/login with internal roles plus controlled manual role login.	High	Backend verifies Google ID token in production, links <code>google_sub</code> , creates app session, supports hashed test passwords for manual verification and never ties to Google for app roles.

ID	Requirement	Priority	Acceptance Criteria
FR-03	Secure session management.	High	Session cookie is HttpOnly/SameSite, logout revoke server session, expired sessions return 401, private pages redirect after logout/back button.
FR-04	Role-based and resource-scoped authorization.	High	Student/Teacher/BranchDirector/GeneralDirector/ access is enforced by middleware and resource-scoped policy; BranchDirector access is limited to assigned branches.
FR-05	Branch, student, teacher, class group, enrollment and class session management.	High	Directors/Admin manage scoped academic data; students/teachers see only linked context; group capacity, branch/level compatibility, schedule conflict and lifecycle transitions are enforced.
FR-06	Dance category/style management.	Medium	Urban, Tropical and Ethnic styles are seeded and manageable through API.
FR-07	Roster-based student attendance.	High	Teacher/director saves a draft or finalizes the exact historical roster; a final correction is director-only, reasoned, versioned and audited.
FR-08	Teacher check-in/check-out and payroll evidence.	High	Check-in is tied to the assigned scheduled session allowed time window; checkout snapshots rate and capped payable minutes for historical reporting.
FR-09	Absence justifications.	Medium	Authorized users submit HTTPS evidence for an absence; directors approve/reject it without rewriting the physical attendance fact.
FR-10	Scholarship eligibility and evaluation.	High	Only finalized sessions count; eligibility requires threshold (default 90%), at least eight counted sessions and director theory/practice approval.
FR-11	Level promotion eligibility and evaluation.	High	An active B1 student needs at least 85% attendance at least eight finalized counted sessions plus consistency/theory/practice approval before automatic promotion.
FR-12	Teacher worked hours and payment report.	Medium	Date-filtered closed shifts use the historical rate and payable-minute snapshot and expose a traceable breakdown.
FR-13	Branch and consolidated reports.	High	Scoped reports expose attendance, punctuality, occupancy/waitlist, income/reversals, receivables/lead funnel, trends and data-quality alerts.
FR-14	Audit logs.	High	Security, administrative, academic, commercial and financial mutations are recorded atomically and can be filtered/paginated by authorized global roles.

ID	Requirement	Priority	Acceptance Criteria
FR-15	Controlled cache management for safe repeated reads.	Medium	Public, private, no-store and memory-cache policies explicit; cache hits/misses are visible through head state-changing actions invalidate affected cache tags.
FR-16	Controlled enrollment and capacity workflow.	High	Student/group links keep non-overlapping historic episodes and controlled statuses; active/trial seats consume capacity, overflow becomes waitlisted, and later re-enrollment creates a new episode.
FR-17	Lead pipeline.	High	Public requests are deduplicated for 24 hours and only through pending/contacted/trial_scheduled/enrolled/lost; 1 loss and conversion evidence is mandatory where applicable.
FR-18	Student financial ledger.	High	Charges derive student branch, prevent active duplicates, maintain coherent dates/statuses and correct posted payments only through immutable linked reversals.
FR-19	Class scheduling lifecycle.	High	Sessions start scheduled, cannot conflict for group/teacher, last at most six hours, require a reason to cancel and become immutable after completion/cancellation.
FR-20	Useful role-specific UX.	High	Students see their academic/financial evidence, teachers operate assigned roster and shift, directors operate branch workflows, and global roles see consolidated controls.
FR-21	Operational data-quality monitoring.	High	Reports identify stale check-ins, unfinalized session duplicate/orphan financial data, enrollment mismatch/overcapacity and overdue lead follow-up.

Non-Functional Requirements

ID	Requirement	Evidence
NFR-01	REST API versioned with <code>/api/v1</code> .	<code>06Code/src/routes/api.js</code>
NFR-02	Clean Code, MVC, services and repositories.	Controllers delegate to services; persistence is isolated by repository classes.

ID	Requirement	Evidence
NFR-03	PostgreSQL normalized schema and controlled reference data.	Ordered <code>06Code/migrations/001_*.sql</code> – <code>012_*.sql</code> , Prisma mapping and localhost-only demo seeds.
NFR-04	No production secrets in repository.	<code>.env.example</code> , Postman and deployment documentation contain placeholders only; real secrets are injected outside version control.
NFR-05	Restricted CORS.	<code>CORS_ORIGINS</code> env configuration.
NFR-06	Public/auth rate limiting.	<code>express-rate-limit</code> protects email login, Google login and public enrollment submission.
NFR-07	Consistent JSON responses.	<code>ApiResponse</code> success/error envelope.
NFR-08	Centralized validation.	Zod validators under <code>src/validators</code> .
NFR-09	Consistent error handling.	<code>AppError</code> and <code>errorHandler</code> middleware.
NFR-10	AWS deployment preparation.	EC2/RDS/ALB guide and PlantUML deployment diagram.
NFR-11	Production-safe configuration.	Production/staging fails fast on default secrets, missing database URL or enabled mock Google tokens.
NFR-12	Controlled HTTP and in-memory cache behavior.	<code>03Documentation/cache-management.md</code> , <code>06Code/src/services/CacheService.js</code> , <code>06Code/src/middleware/cacheControl.js</code> , <code>070ther/nginx-alc-frontend.conf</code>
NFR-13	Auditable transactional mutations.	Business writes and their audit rows share a database transaction; concurrency-sensitive enrollment, attendance, leads and finance use transactional checks.
NFR-14	Safe schema evolution.	Ordered SQL migration runner uses advisory lock, per-file transaction, immutable checksum and <code>sche ma_migrations</code> ; no schema-push deployment path.
NFR-15	Web security baseline.	Exact-origin CORS, secure cookie policy, CSRF for cookie writes, HTTPS enforcement, CSP/Helmet, bounded JSON and redacted errors with request IDs.
NFR-16	Measurable reports.	Every report declares period, <code>generatedAt</code> , historical <code>asOf</code> , timezone and formulas; range is capped at 1095 days.

ID	Requirement	Evidence
NFR-17	Sanitized operational health.	<code>/api/v1/health/live</code> proves process liveness; <code>/api/v1/health/ready</code> checks persistence and returns <code>503</code> without infrastructure details when unavailable.

User Stories

ID	Story
US-01	As a Visitor, I want to request enrollment from the public page so the academy can contact me.
US-02	As a Student, I want secure access to my private academic system session.
US-03	As a Teacher, I want to record student attendance and check in/out for my worked hours.
US-04	As a BranchDirector, I want to manage students, teachers, enrollments, capacity, sessions, leads, charges and justifications only for my branch.
US-05	As a BranchDirector, I want to review scholarship and promotion candidates before registering evaluations.
US-06	As a GeneralDirector, I want consolidated reports, trends, financial reversals, quality alerts and audit logs so I can control the academy.
US-07	As an Admin, I want to assign internal roles, branch access and role-test users without depending on Google profile data.
US-08	As a school director, I want repeated catalog and report reads to be faster while private academic data remains protected from browser or shared-cache reuse.
US-09	As a commercial coordinator, I want every lead to have a valid next state, follow-up and conversion evidence so opportunities are not silently lost.
US-10	As a Student, I want to see my groups, sessions, attendance, justifications, payments and events without seeing another student's data.

Role/Permission Matrix

Feature	Visitor	Student	Teacher	BranchDirector
View landing page	X	X	X	
Submit enrollment request	X			
Login/logout/session		X	X	

Feature	Visitor	Student	Teacher	BranchDirector
List own/private data		X	X	
View own groups/sessions/payments/attendance		X		
Save/finalize assigned roster attendance			X	
Correct finalized attendance with reason				
Teacher check-in/out			X	
Submit absence justification		X	X	
Review absence justification				
Manage scoped academic/enrollment/session data				
Manage lead pipeline				
Manage scoped charges				
Reverse paid charge				
Scholarship/promotion evaluation				
Branch reports				
Consolidated reports				
Audit logs				
Assign roles				
Assign branch access				
Use temporary seeded role login		X	X	

Business Rules

- BR-01: A scholarship candidate requires the active rule threshold (default 90%), at least eight finalized accountable sessions and an active student. Approved excuses leave the raw absence visible but remove it from the adjusted denominator.
- BR-02: Scholarship approval is never automatic; a director records theory and practice scores, both at least 70, and chooses 25%, 50%, 75% or 100%.
- BR-03: Promotion applies only from active B1 to B2; candidacy requires at least 85% adjusted attendance and eight finalized accountable sessions.

Approval additionally requires consistency, theory and practice scores of at least 70, updates the level atomically and cannot duplicate an approved B1→B2 transition.

- BR-04: A group enrollment requires matching branch and level plus active resources when occupying a seat. `active` and `trial` consume capacity; overflow is `waitlisted`.
- BR-05: Enrollment statuses follow the explicit transition graph and keep effective dates. `withdrawn` requires a reason. Re-enrollment creates a new non-overlapping row only when every prior episode is withdrawn/completed with `endsAt`; any active/trial/waitlisted/frozen episode blocks it. Historical rosters select the episode covering the session date.
- BR-06: Attendance is `present`, `late` or `absent`; a draft may be saved after class starts, but finalization/correction waits until `endsAt`, requires the exact roster and completes the session. Finalized attendance cannot return to draft.
- BR-07: Only a director may correct finalized attendance; every correction needs a reason, increments version, is audited and invalidates incompatible pending/approved justifications.
- BR-08: A class is scheduled for an active group, lasts no more than six hours and cannot overlap another non-cancelled session for its group or assigned teacher. Cancellation requires a reason; completed/cancelled sessions are immutable.
- BR-09: Teacher check-in requires the teacher's assigned scheduled class and is available from 60 minutes before through 60 minutes after class. Only one open shift and one teacher/session shift are allowed.
- BR-10: Payable time is capped at actual time, scheduled duration plus 30 minutes and 12 hours. Checkout snapshots hourly rate and payable minutes.
- BR-11: Leads start `pending`, reject active duplicates for the same email/branch within 24 hours and follow the controlled pending/contacted/trial_scheduled/enrolled/lost graph. Trial needs a future date, loss needs a reason and enrollment needs a real active matching student.
- BR-12: A charge derives branch from its student, uses a valid `YYYY-MM` period and positive amount, and is unique among non-cancelled rows by student/period/normalized concept.
- BR-13: Paid/cancelled ledger rows are immutable. Only GeneralDirector/Admin may reverse a paid charge, once, using a linked negative row and mandatory reason.
- BR-14: Roles are owned by the application, never inferred from Google. Only Admin may grant Admin or GeneralDirector; role/profile/branch prerequisites are enforced.
- BR-15: BranchDirector requires explicit branch assignment and cannot access or mutate other branches or global catalogs/rates. Student and Teacher see only own/enrolled/assigned context.

- BR-16: Password changes revoke previous sessions and rotate the current session. Inactive users and revoked/expired sessions fail authentication.
- BR-17: Cookie-authenticated writes require CSRF protection; all private responses are no-store and deployed cookies/transport use the secure production policy.
- BR-18: Every administrative, academic, commercial, financial and security mutation is audited with actor, action, entity, sanitized decision metadata and bounded request context (request ID, method/path, IP and user agent) for correlation.
- BR-19: Management reports count finalized, non-cancelled academic evidence, distinguish raw/adjusted attendance and gross/net/reversed income, and publish historical `asOf` separately from generation time.
- BR-20: Cacheable non-sensitive responses declare TTL/evidence headers and every relevant mutation invalidates its tags.

Remaining Production Backlog

1. Rotate/revoke any previously exposed external credentials and verify deployed `/db-admin/` removal; repository sanitization is not external rotation evidence.
2. Add a CI job with disposable PostgreSQL that applies all migrations from zero, runs both Prisma smoke checks and destroys the database.
3. Exercise restore/PITR, migration rollback procedure and financial/attendance reconciliation in staging.
4. Connect readiness, application/request IDs, RDS, ALB and data-quality alerts to centralized monitoring and incident ownership.
5. Perform accessibility and end-to-end browser regression on the role matrix with production-like data volumes.
6. Plan major framework upgrades as dedicated migrations after functional/security baselines remain green.

Requirement-To-Endpoint Traceability

Requirement	Endpoints
FR-01	<code>GET /</code> , <code>POST /api/v1/enrollment-requests</code>
FR-02	<code>POST /api/v1/auth/google</code> , <code>POST /api/v1/auth/login</code> , <code>GET /api/v1/users</code> , <code>PATCH /api/v1/users/{id}/role</code>
FR-03	<code>GET /api/v1/auth/me</code> , <code>POST /api/v1/auth/logout</code> , <code>/private/dashboard.html</code>
FR-04	All protected endpoints through <code>requireAuth</code> / <code>allowRoles</code>

Requirement	Endpoints
FR-05	<code>/api/v1/branches</code> , <code>/api/v1/students</code> , <code>/api/v1/teachers</code> , <code>/api/v1/class-groups</code> , <code>/api/v1/class-group-enrollments</code> , <code>/api/v1/class-sessions</code>
FR-06	<code>/api/v1/dance-categories</code> , <code>/api/v1/dance-styles</code>
FR-07	<code>GET /api/v1/class-sessions/{id}/roster</code> , <code>PUT /api/v1/class-sessions/{id}/attendance</code> , <code>POST /api/v1/student-attendance</code>
FR-08	<code>POST /api/v1/teacher-attendance/check-in</code> , <code>PATCH /api/v1/teacher-attendance/{id}/check-out</code>
FR-09	<code>/api/v1/absence-justifications</code> , <code>/api/v1/absence-justifications/{id}/review</code>
FR-10	<code>GET /api/v1/reports/scholarships/{studentId}/candidate</code> , <code>/api/v1/scholarship-evaluations</code>
FR-11	<code>GET /api/v1/reports/level-promotions/{studentId}/candidate</code> , <code>/api/v1/level-promotion-evaluations</code>
FR-12	<code>GET /api/v1/teacher-attendance</code> , <code>GET /api/v1/reports/teachers/{teacherId}/payment?from=&to=</code>
FR-13	<code>GET /api/v1/reports/branches/summary</code> , <code>GET /api/v1/reports/general</code> , <code>GET /api/v1/reports/branches/{branchId}/detail</code>
FR-14	<code>GET /api/v1/audit-logs?action=&entity=&actorUserId=&from=&to=&limit=&offset=</code>
FR-15	<code>GET /api/v1/auth/config</code> , <code>GET /api/v1/roles</code> , <code>GET /api/v1/branches</code> , <code>GET /api/v1/reports/branches/summary</code> , <code>static /assets/*</code> , <code>protected /api/analytics/v1/*</code>
FR-16	<code>GET/POST/PATCH /api/v1/class-group-enrollments</code>
FR-17	<code>POST/GET /api/v1/enrollment-requests</code> , <code>PATCH /api/v1/enrollment-requests/{id}/status</code>
FR-18	<code>GET/POST/PATCH /api/v1/student-payments</code> , <code>POST /api/v1/student-payments/{id}/reversal</code>
FR-19	<code>GET/POST/PATCH /api/v1/class-sessions</code>
FR-20	React role modules under <code>/private/dashboard.html</code> using the scoped endpoints above.
FR-21	<code>qualityAlerts</code> in general, branch summary and branch detail report responses.

